

해사 사이버안전 관리지침

제1조(목적) 이 지침은 선박운항을 위협하는 해사 사이버 공격으로부터 선박운항시스템 등을 보호하고, 선박 및 사업장의 효율적인 해사 사이버안전 관리 지원을 목적으로 한다.

제2조(정의) 이 지침에서 사용하는 용어의 뜻은 다음과 같다.

1. "해사 사이버안전"이란 해사 사이버 공격으로부터 선박 운항에 필요한 시스템(이하 "선박운항시스템"이라 한다)을 보호함으로써 선박운항시스템과 정보의 기밀성·무결성·가용성 등 안전성을 유지하는 상태를 말한다.
2. "해사 사이버 공격·위협"이란 해킹, 컴퓨터 바이러스, 서비스 거부, 전자기파 등 전자적 수단으로 선박운항시스템 또는 이와 관련된 정보시스템을 침입·교란·마비·파괴하거나 정보를 위조·변조·훼손·훔치는 행위 및 그와 관련된 위협을 말한다.
3. "해사 사이버안전 관리체계"란 선박운항과 관련한 사이버 위협성을 분별·분석·평가하여 사이버 위협성을 수용·회피·전이·완화 조치하는 절차를 말한다.
4. "선박소유자"란 「해상교통안전법」 제46조제2항에 따라 안전관리체제를 수립·시행하여야 하는 선박소유자(같은 조 제4항에 따라 안전관리체제의 수립·시행을 위탁한 경우에는 위탁받은 자를 말한다)를 말한다.

제3조(적용 범위 및 다른 규정과의 관계) ① 이 지침은 「해상교통안전법」 제46조에 따른 안전관리체제를 수립하여 시행하는 선박 및 사업장에 적용한다.

② 다른 법령에 특별한 규정이 있는 경우를 제외하고는 이 지침에서 정하는 바에 따른다.

제4조(해사 사이버안전 대책의 수립·시행 등) ① 해양수산부장관은 해사 사이버안전 확보를 위하여 필요한 대책을 수립하여 시행할 수 있다.

② 해양수산부장관은 해사 사이버 안전관리를 위해 필요한 전문기술 인력 확보, 교육프로그램의 개발, 전문인력 양성 등 필요한 조치를 마련할 수 있다.

③ 해양수산부장관은 해사 사이버 공격·위협에 대비하여 선박운항시스템 보호 및 해사 사이버안전 업무수행에 필요한 전략·기술을 연구·개발하고, 선박 및 사업장 등에 보급할 수 있다.

제5조(해사 사이버안전 진단 및 실태평가 등) ① 해양수산부장관은 해사 사이버안전 대책 시행과 해사 사이버 공격·위협에 대한 예방 및 대응지원을 위해 필요한 경우에는 선박 및 사업장에 대한 진단 또는 실태평가를 실시할 수 있다.

② 해양수산부장관은 사업장의 해사 사이버안전 관리 지원을 위해 선박운항시스템 또는 이와 관련된 정보시스템의 취약요소를 발굴·개선하는 등 선박 및 사업장의 사이버안전 관리에 대하여 상담할 수 있다.

③ 해양수산부장관은 제1항에 따른 진단 또는 실태평가 결과 취약요소가 발견된 경우에는 이를 시정하는 등 필요한 조치를 선박소유자에 요청할 수 있다.

제6조(해사 사이버 공격·위협에 대한 예방·대응 교육 및 훈련) ① 해

양수산부장관은 해사 사이버 공격·위협에 대한 예방 등을 위하여 선박운항과 관련한 종사자 교육을 직접 실시하거나 다른 기관·단체의 교육과정을 수강하도록 지정할 수 있다.

② 해양수산부장관은 해사 사이버 공격·위협에 효과적으로 대응하기 위하여 선박운항과 관련한 종사자가 참여하는 훈련을 실시할 수 있다.

제7조(기관 간 협력체계 구축) 해양수산부장관은 해사 사이버안전 관리

업무 수행을 위하여 필요한 경우에는 관계 중앙행정기관, 지방자치단체, 「고등교육법」에 따른 대학, 「공공기관의 운영에 관한 법률」에 따른 공공기관, 「해상교통안전법」 제50조제1항에 따른 정부대행기관 등과 협력체계를 구축할 수 있다.

제8조(해사 사이버안전 관리의 기능적 요소) ① 효과적인 해사 사이버

안전 관리절차 수립·이행 등을 위해 고려해야 할 기능적 요소는 다음 각 호와 같다.

1. 식별: 해사 사이버안전 관리를 위한 인적자원의 역할 및 책임을 정의하고, 해사 사이버 공격·위협으로 선박운항에 위협을 줄 수 있는 시스템, 자산, 데이터 및 기능을 확인
2. 보호: 해사 사이버 공격·위협으로부터 선박운항시스템을 보호하

고, 위험 통제절차와 방안, 해사 사이버 사고에 대비한 비상계획을 구현

3. 탐지: 해사 사이버 사고를 알아내는데 필요한 활동을 개발하고 구현

4. 대응: 해사 사이버 사고로 인해 손상된 선박운항 및 서비스에 필요한 시스템을 복원하기 위한 활동과 계획을 개발하고 구현

5. 복구: 해사 사이버 사고로 영향을 받은 선박운항시스템을 백업(backup)하고 복원하는 조치

② 선박소유자는 해사 사이버안전 관리의 기능적 요소들을 해사 사이버안전 관리체계에 연속적으로 적절하게 통합되도록 관리해야 한다.

제9조(해사 사이버안전 관리조직 수준) 선박소유자가 해사 사이버안전 조직을 구성하는 경우에는 사업장의 모든 직원과 선박의 선원까지 관리조직의 모든 수준을 고려해야 한다.

제10조(해사 사이버안전 확보를 위한 자산관리) ① 선박소유자는 효과적인 해사 사이버안전 관리를 위해서 취약시스템을 분별하여 알아보고, 목록 작성 등 자산관리를 위한 조치를 할 수 있다.

② 선박의 주요한 취약시스템에는 선교(船橋) 시스템, 화물 취급 및 관리 시스템, 추진 및 기관관리 시스템, 동력제어 시스템, 접근통제 시스템, 여객 서비스 및 관리 시스템, 여객 공공 네트워크, 행정, 승무원 복지 시스템, 통신 시스템 등이 있다.

제11조(해사 사이버안전 확보를 위한 업무분장) 선박소유자는 효과적인 해사 사이버안전 관리체계 운영을 위해 선박 및 사업장의 특성에

따라 해사 사이버안전 관리업무를 분별하여 알아본 후 업무총괄자와 담당자를 지정하고, 업무담당자들의 책임과 의무 등의 내용을 문서화할 수 있다.

제12조(해사 사이버안전 위협성 평가 등) ① 선박소유자가 해사 사이버 위협성을 평가하는 경우에는 주요 시스템에 대한 위협을 분별하여 알아보고, 해사 사이버 공격·위협의 발생빈도와 해사 사이버 공격·위협으로 인한 영향을 결합하여 위협성 수준을 결정할 수 있으며, 위협성 평가절차는 별표 1과 같다.

② 위협성을 평가하는 경우에는 해사 사이버 공격·위협의 종류는 의도된 행동(표적공격)과 의도되지 않은 행동(비표적공격)으로 구분할 수 있다.

③ 선박소유자가 해사 사이버안전 관리체계를 구축하는 경우에는 위협성 평가를 통해 확인된 위협성의 감소방안을 포함하도록 고려해야 한다. 이 경우 감소방안은 발생빈도를 줄이는 방안과 영향을 최소화하는 방안으로 구분할 수 있다.

제13조(해사 사이버안전 확보를 위한 보호조치) ① 선박소유자가 해사 사이버안전 관리체계를 구축하는 경우에는 선박운항시스템 등 주요 자산에 대한 보호조치를 고려해야 한다.

② 제1항에 따른 보호조치에는 사용자 계정 관리, 인증 및 접근통제 조치, 해사 사이버안전 인식제고 교육, 해사 사이버안전 자산의 유지보수 등이 있다.

③ 주요 자산에 대한 보호방안을 수립하는 경우에는 기술적 보안, 물리적 보안, 관리적 보안 방안으로 구분하여 수립할 수 있다.

제14조(해사 사이버안전 확보를 위한 탐지조치) 선박소유자가 해사 사이버안전 관리체계를 구축하는 경우에는 선박운항시스템 등 주요 자산의 위험성 수준에 따른 적절한 탐지조치를 고려해야 한다.

제15조(해사 사이버안전 확보를 위한 대응조치) ① 선박소유자가 해사 사이버안전 관리체계를 구축하는 경우에는 해사 사이버 사고 대응을 위한 조치를 고려해야 한다.

② 제1항에 따른 대응조치에는 다음 각 호의 사항을 포함할 수 있다.

1. 해사 사이버 공격·위협에 대한 대응계획 또는 절차
2. 대응활동을 위한 내부 및 외부 소통·협력체계
3. 탐지·대응 활동 결과에 따른 조직 대응활동 개선조치

제16조(해사 사이버안전 확보를 위한 복구조치) ① 선박소유자가 해사 사이버안전 관리체계를 구축하는 경우에는 해사 사이버 공격·위협의 영향을 신속하게 복구하기 위한 조치를 고려해야 한다.

② 제1항에 따른 복구조치에는 다음 각 호의 사항을 포함할 수 있다.

1. 해사 사이버 공격·위협의 영향을 받는 시스템 또는 자산의 복구를 위한 비상계획 또는 절차
2. 복구활동을 위한 내부 및 외부 소통·협력체계
3. 복구활동 결과에 따른 복구계획 및 절차 개선

제17조(사고통보 및 조사) ① 해사 사이버 공격·위협으로 인한 선박

운항불가 등 해양사고가 발생하거나 발생할 우려가 있는 경우에 선박 소유자 등은 피해를 최소화하는 조치 후 그 사실을 지체 없이 별표 2에 따라 해양수산부장관에게 통보해야 한다.

② 해양수산부장관이 제1항에 따라 사고를 통보받은 경우에는 그 내용 등을 별표 2에 따라 관련 부서·기관 등에 전파·보고하고, 사고 대응 및 복구지원 조치 등을 할 수 있다.

③ 해양수산부장관은 해사 사이버 공격·위협으로 선박 운항불가 등의 피해가 발생한 사고에 대하여 필요한 경우에는 원인분석 및 피해 내용 확인 등을 위한 조사를 실시할 수 있다.

④ 해양수산부장관은 해사 사이버 공격·위협으로 인해 운항이 불가능한 선박이 다른 선박의 항행안전을 방해할 우려가 있거나 다른 선박에 비슷한 해사 사이버 공격·위협 우려가 있는 경우에는 사고정보 등을 다른 선박과 사업장에 알려줄 수 있다.

제18조(국제표준 및 산업표준의 활용) ① 선박소유자가 해사 사이버안전 관리체계를 구축하는 경우에는 이 지침 이외에 국제표준 및 산업표준의 요구사항을 활용할 수 있다.

② 제1항에 따른 국제표준 및 산업표준에는 다음 각 호의 지침 등이 포함될 수 있다.

1. 국제해사기구(IMO)의 「해상 사이버 위험관리 지침」(「GUIDELINES ON MARITIME CYBER RISK MANAGEMENT, MSC-FAL.1/Circ.3」)

2. 국제해운회의소(ICS), 국제해상보험연합(IUMI), 발틱국제해사협회의(BIMCO), 국제정유사해운포럼(OCIMF), 국제탱커선주협회(INTERNATANKO), 국제건화물선주협회(INTERCARGO), 국제선박관리자협회(InterManager), 세계선사협의회(WSC) 및 슈퍼요트조선협회(SYBAAss) 등에서 제작 및 배포하는 선상 사이버 보안지침
 3. 사이버 복원에 대한 통합 국제선급협회(IACS) 권장사항
 4. 국제표준화기구(ISO)와 국제전기기술위원회(IEC)가 공동 발행한 정보기술에 대한 ISO/IEC 27001 표준
 5. 미국 국립표준기술연구소(National Institute of Standards and Technology)의 중요 기반 사이버 보안 개선을 위한 체제
- ③ 제2항의 국제표준 및 산업표준이 개정된 경우에는 개정된 기준을 적용할 수 있다. 다만, 해당 국제표준 및 산업표준이 폐지된 경우에는 대체기준 등을 적용할 수 있다.

제19조(재검토기한) 해양수산부장관은 「훈령·예규 등의 발령 및 관리에 관한 규정」에 따라 이 고시에 대하여 **2024년 1월 1일** 기준으로 매 3년이 되는 시점(매 3년째의 12월 31일까지를 말한다)마다 그 타당성을 검토하여 개선 등의 조치를 해야 한다.

부 칙

이 고시는 발령한 날부터 시행한다.

[별표 1]

해사 사이버안전 위험성 평가절차(제12조제1항 관련)

1. 사전 평가 활동

- 가. 운항시스템에 대한 자료를 검토하고, 기밀성·무결성·가용성 등을 고려하여 잠재적인 영향 수준을 평가한다.
- 나. 중요한 선상 장비의 주요 제조업체를 분별하여 알아보고, 협력관계를 구축한다.
- 다. 선박의 유지관리 및 운항시스템 지원에 대한 상세 자료를 검토한다.
- 라. 선상 네트워크 및 장비의 유지관리·지원에 대하여 선박소유자(운영자)가 가질 수 있는 계약요건 및 의무를 설정한다.

2. 선박 평가

- 가. 선박의 네트워크, 시스템 및 장치에 대한 평가 목표는 기밀성 손실, 무결성 손실, 선박 자체의 작동 손실을 초래하거나 손상시킬 수 있는 취약성을 분별하여 알아보는 것이며, 소프트웨어 결함 등 기술적 취약점, 네트워크 설계, 방화벽 구성 등 구현 오류, 절차 또는 그 밖에 사용자 오류 등의 범주에 속할 수 있다.
- 나. 평가 중 수행되는 활동에는 방화벽을 포함한 모든 컴퓨터, 서버, 라우터 및 사이버 보안기술의 구성 검토가 포함될 수 있다.
- 다. 선박 평가는 선장, 기관장, 1등항해사 및 1등기관사를 포함한 모든 선원이 참여해야 하며, 이 절차를 통해 실제 선박 운항시스템의 구현과 이와 관련된 설계자료의 차이, 선원에게 제공되는 사이버 교육 수준을 이해할 수 있다.

3. 보고 및 취약성 검토

- 가. 평가 후 확인된 각 취약성은 잠재적 영향과 악용 가능성에 대해 평가가 필요하며, 각 취약성에 대해 권장되는 기술 및 절차적 수정 조치가 구별해야 한다.
- 나. 해사 사이버 위험성 평가에는 다음을 포함해야 한다.
 - 1) 평가된 선박의 결과, 권장사항 및 전체 보안개요에 대한 사항
 - 2) 발견된 취약성 분석, 악용 가능성, 이에 따른 영향 등 기술적 발견

- 3) 측정의 효율성, 비용, 적용 가능성 등을 반영하여 우선순위를 정한 작업 목록
 - 4) 모든 주요 평가결과에 대한 포괄적 분석이 포함된 보충자료
 - 5) 해사 사이버 위험성 평가팀이 수행한 활동기록 및 참여 중 사용된 도구
- 다. 해사 사이버 위험성 평가의 일부를 기밀로 취급해야 하는지를 고려해야 한다.
- 라. 해사 사이버 위험관리 정책 및 절차는 선박 및 사업장 안전관리체제에 포함되어야 하나, 선박 및 사업장 외부에 제공될 경우에는 취약할 수 있는 정보는 포함하지 않는다.

4. 제조업체 보고

- 가. 선박소유자가 조사결과를 검토, 논의 및 평가하는 경우에는 조사결과에 따라 제조업체에서 개발한 개선계획이 본질적으로 완벽하며 취약성을 제거하기 위한 올바른 해결방안을 분별하여 알아보는 것을 보장하기 위해 영향을 받는 시스템의 제조업체에 조사결과를 보낼 수 있다.
- 나. 제조업체에게 공개하기 위해 선박소유자가 승인한 모든 결과는 외부 전문가의 지원을 받아 추가로 분석될 수 있으며, 외부 전문가는 문제에 대한 완전한 위험과 기술적 이해를 보장하기 위해 제조업체의 사이버 보안 담당자와 협력해야 한다.

[별표 2]

해사 사이버 공격·위협의 사고 통보·보고절차(제17조 관련)

1. 선박소유자, 운항자, 안전관리책임자·대행자 등은 제17조제1항에 따라 해사 사이버 공격·위협으로 인해 「해양사고 등의 보고 및 수습에 관한 규정」 제2조 제9호에 따른 해양사고 등이 발생하거나 발생할 우려가 있는 경우에 지체 없이 관련 사항에 대하여 해양수산부장관에게 통보해야 한다.
2. 상황 통보 시 개요, 피해사항, 선박의 상세제원, 조치사항 등을 포함하고, 상황 변동 및 추가사항 발생 시 지체 없이 통보한다.
3. 제17조제2항에 따라 해양수산부장관이 해양사고 등에 대하여 통보받은 경우에는 그 내용 등을 「해양수산부 종합상황실 운영 규정」 제10조, 제11조에 따라 접수·통보 및 보고·전파 등을 한다.